



การรักษาความปลอดภัยของ Session และการเข้าสู่ระบบ

Asst.Prof. Monlica Wattana, Ph.D

Department of Computer Science, Khon Kaen University

CP423324 Database and Web Security





Outline

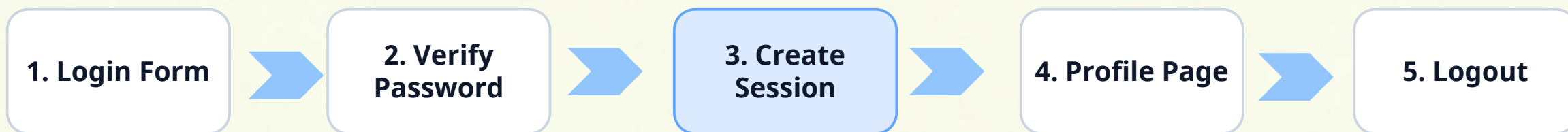


- ขั้นตอนการ Login
- รูปแบบการโจมตีระบบ Login
- Session Fixation vs Session Hijacking
- การรักษาความปลอดภัยของ PHP Session
- ตัวอย่างการ Login/Logout



ขั้นตอนการ Login

การตรวจสอบการ Login

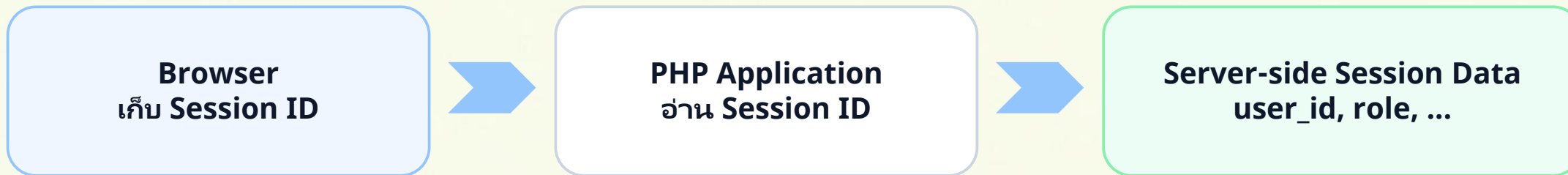


- Password ปกป้องขั้นตอน “ก่อน Login”
- Session ID ปกป้องสถานะ “หลัง Login”
- ดังนั้น Session ID ต้องได้รับการป้องกันเหมือนข้อมูลลับ



ขั้นตอนการ Login

Session เป็นกลไกที่ Server ใช้จดจำสถานะของผู้ใช้



- Session data หลักอยู่ฝั่ง Server
- Browser มักเก็บเพียง Session ID ใน Cookie
- ใน PHP มักพบ Cookie ชื่อ PHPSESSID





ขั้นตอนการ Login



Session ID เสมือน กุญแจ ของ Session

ถ้าผู้โจมตีได้ Session ID ที่ยังใช้งานได้ อาจสวมรอยเป็นผู้ใช้ได้โดยไม่ต้องรู้ Password ดังนั้นควรต้องมีการป้องกัน ดังนี้

- Session ID ต้องคาดเดายากและไม่เปิดเผย
- ไม่ควรใส่ Session ID ใน URL
- ไม่ควรบันทึก Session ID จริงลง Log
- ควรส่งผ่าน Cookie ที่มี Security Flags
- ควรเปลี่ยน Session ID เมื่อระดับสิทธิ์เปลี่ยน เช่น หลัง Login





รูปแบบการโจมตีระบบ Login



1. การโจมตีผ่านช่องโหว่ของโปรแกรม (Injection Attacks)

SQL Injection: การส่งคำสั่ง SQL เข้าไปทางช่อง Input (เช่น ช่อง Username หรือ Password) เพื่อข้ามขั้นตอนการตรวจสอบสิทธิ์หรือดึงข้อมูลจากฐานข้อมูลโดยไม่ได้รับอนุญาต ซึ่งป้องกันได้ด้วยการใช้ Prepared Statement





รูปแบบการโจมตีระบบ Login



2.การโจมตีด้านรหัสผ่าน (Password-based Attacks)

- **Brute Force Attack:** การสุ่มเดารหัสผ่านซ้ำๆ จนกว่าจะถูกต้อง ซึ่งระบบสามารถป้องกันได้ โดยการจำกัดจำนวนครั้งในการ Login (Login Attempt Limiting),
- **Username Enumeration:** การตรวจสอบว่ามีชื่อผู้ใช้นั้นๆ อยู่ในระบบหรือไม่ โดยสังเกตจากข้อความตอบกลับที่แตกต่างกันระหว่าง "ไม่มีชื่อผู้ใช้" กับ "รหัสผ่านผิด"
- **Password Spraying และ Credential Stuffing:** การนำชุดข้อมูล Username และ Password ที่หลุดมาจากเว็บอื่นมาสุ่มลองเข้าใช้งานกับหลายๆ บัญชีในระบบ





รูปแบบการโจมตีระบบ Login



3. การโจมตีด้าน Session (Session-based Attacks)

- **Session Fixation:** เป็นการที่ผู้โจมตีพยายามกำหนดค่า Session ID ให้กับเหยื่อก่อนที่เหยื่อจะเข้าสู่ระบบ เพื่อให้ผู้โจมตีสามารถใช้ Session ID นั้นเข้าสวมรอยเป็นเหยื่อได้หลังจากเหยื่อ Login สำเร็จ
- **Session Hijacking:** การขโมย Session ID ที่กำลังใช้งานอยู่ของผู้ใช้ เพื่อสวมรอยเข้าถึงระบบโดยไม่ต้องทราบรหัสผ่าน การเปลี่ยนแปลงของข้อมูลบริบท เช่น User-Agent อาจใช้เป็นสัญญาณบ่งชี้ความผิดปกติของ Session ได้ แต่ไม่สามารถยืนยันได้ว่าเกิด Session Hijacking โดยลำพัง





Session Fixation



ผู้โจมตีทำให้เหยื่อใช้ Session ID ที่ผู้โจมตีรู้ล่วงหน้า

จุดอ่อนหลัก: Session ID ไม่ถูกเปลี่ยนหลัง Login

Attacker
ได้ Session ID
= ABC123



Victim
ใช้ ABC123



Victim Login
สำเร็จ



Server ยังใช้
ABC123



Attacker ใช้
ABC123 เข้า
ระบบ





Session Hijacking



ผู้โจมตีขโมย Session ID ที่กำลังใช้งานอยู่

- ดัก Cookie บนเครือข่ายที่ไม่ปลอดภัย
- XSS ทำให้ข้อมูล Session รั่ว
- Session ID ถูกบันทึกหรือเปิดเผยโดยไม่ตั้งใจ
- เครื่องสาธารณะหรืออุปกรณ์ที่ถูกควบคุม
- Cookie ไม่มี Secure / HttpOnly ที่เหมาะสม

Valid User
PHPSESSID=XYZ789



Server
เห็น Session ID เดียวกัน

Attacker
ขโมย XYZ789





Session Fixation vs Session Hijacking



ประเด็น	Session Fixation	Session Hijacking
แนวคิด	กำหนด Session ID ให้เหยื่อใช้	ขโมย Session ID ที่กำลังใช้งาน
ช่วงเวลา	ก่อน/ขณะ Login	หลัง Session ถูกสร้างแล้ว
Password จำเป็นหรือไม่	ไม่จำเป็น	ไม่จำเป็น
การป้องกันหลัก	Regenerate Session ID	HTTPS + Secure Cookie + XSS Protection
ผลกระทบ	สวมรอยเป็นผู้ใช้	สวมรอยเป็นผู้ใช้





การรักษาความปลอดภัยของ PHP Session



1. Regenerate Session ID หลัง Login (เปลี่ยน Session ID หลังยืนยันตัวตนสำเร็จ) เพื่อสร้าง Session ID ใหม่หลังยืนยันตัวตนสำเร็จ

- ลดความเสี่ยง Session Fixation
- สร้าง Session ID ใหม่เมื่อสิทธิ์เปลี่ยน
- ข้อมูล Session ยังคงใช้งานต่อได้



Security Boundary: เมื่อระดับสิทธิ์เปลี่ยน ควรเปลี่ยน Session ID





การรักษาความปลอดภัยของ PHP Session



1. Regenerate Session ID หลัง Login (ต่อ)

ตัวอย่างคำสั่ง

```
if ($user && password_verify($password, $user['password_hash'])) {  
  
    session_regenerate_id(true);  
  
    $_SESSION['user_id'] = (int) $user['id'];  
    $_SESSION['username'] = $user['username'];  
    $_SESSION['role'] = $user['role'];  
}
```

ใช้หลัง Login สำเร็จ





การรักษาความปลอดภัยของ PHP Session



2. กำหนด Session Timeout จำกัดอายุของ Session เพื่อลดความเสี่ยงจาก Session ที่ค้าง โดยควรมีอย่างน้อย 2 แบบ คือ

1) Idle Timeout หมดอายุเมื่อไม่มีการใช้งานเกินเวลาที่กำหนด

- นับจากกิจกรรมล่าสุด
- ต่ออายุเมื่อมี Request ใหม่
- เหมาะกับ Session ที่ถูกทิ้งไว้

2) Absolute Timeout หมดอายุเมื่อครบเวลาสูงสุดนับจาก Login แม้ผู้ใช้จะยังใช้งานอยู่

- นับจากเวลา Login
- ไม่ต่ออายุแม้ใช้งานต่อเนื่อง
- จำกัดอายุสูงสุดของ Session





การรักษาความปลอดภัยของ PHP Session



2. กำหนด Session Timeout จำกัดอายุของ Session (ต่อ)

1) Idle Timeout หมดอายุเมื่อไม่มีการใช้งานเกินเวลาที่กำหนด

```
const IDLE_TIMEOUT = 900; // 15 นาที

if (isset($_SESSION['last_activity']) &&
    time() - $_SESSION['last_activity'] > IDLE_TIMEOUT) {
    // destroy session
}

$_SESSION['last_activity'] = time();
```

ควรตรวจฝั่ง Server ไม่ควรพึ่ง Browser Timer ต้องอัปเดต last_activity เมื่อมี Request





การรักษาความปลอดภัยของ PHP Session



2. กำหนด Session Timeout จำกัดอายุของ Session (ต่อ)

2) Absolute Timeout: Session ต้องหมดอายุเมื่อครบเวลาสูงสุด แม้ผู้ใช้ยังใช้งาน

- ใช้ร่วมกับ Idle Timeout
- ไม่ reset เมื่อ Refresh
- ลดการใช้งาน Session ที่ยาวเกินไป

```
const ABSOLUTE_TIMEOUT = 28800; // 8 ชั่วโมง
```

```
if (isset($_SESSION['login_time']) &&  
    time() - $_SESSION['login_time'] > ABSOLUTE_TIMEOUT) {  
    // destroy session  
}
```





การรักษาความปลอดภัยของ PHP Session



2. กำหนด Session Timeout จำกัดอายุของ Session (ต่อ)

Idle Timeout vs Absolute Timeout

ประเด็น	Idle Timeout	Absolute Timeout
เริ่มนับจาก	กิจกรรมล่าสุด	เวลาที่ Login
ต่ออายุเมื่อใช้งาน	ใช่	ไม่
ป้องกัน	Session ที่ถูกทิ้งไว้	Session ที่มีอายุยาวเกินไป
ตัวแปรตัวอย่าง	<code>\$_SESSION['last_activity']</code>	<code>\$_SESSION['login_time']</code>





การรักษาความปลอดภัยของ PHP Session



3. ตั้งค่า Session Cookie ให้ปลอดภัย

Cookie ที่ไม่ปลอดภัย = Session ID ที่เสี่ยงถูกขโมยหรือถูกส่งในบริบทที่ไม่เหมาะสม

PHPSESSID = ...



Browser Request



PHP Server



การรักษาความปลอดภัยของ PHP Session

3. ตั้งค่า Session Cookie ให้ปลอดภัย โดยใช้ session_set_cookie_params() ก่อน session_start()

```
$isHttps = isset($_SERVER['HTTPS']) && $_SERVER['HTTPS'] !== 'off';
```

```
session_set_cookie_params([  
    'lifetime' => 0,  
    'path' => '/',  
    'secure' => $isHttps,  
    'httponly' => true,  
    'samesite' => 'Lax'  
]);
```

```
session_start();
```

ต้องเรียกก่อน **session_start()**

lifetime = 0 → Session Cookie

secure → ส่งผ่าน HTTPS

httponly → JavaScript อ่าน Session Cookie ไม่ได้โดยตรง

samesite → ควบคุมการส่งข้ามไซต์

หมายเหตุ:

- Production: ควรใช้ HTTPS และ Secure=true
- Lab บน http://localhost:8080 อาจใช้ secure=false จึงตรวจ \$isHttps แบบอัตโนมัติได้



การรักษาความปลอดภัยของ PHP Session



3. ตั้งค่า Session Cookie ให้ปลอดภัย

SameSite Cookie ควบคุมการส่ง Cookie ในคำขอข้ามเว็บไซต์

ค่า	แนวคิด	หมายเหตุ
Strict	จำกัดมากที่สุด	ปลอดภัยสูง แต่อาจกระทบ UX
Lax	สมดุลระหว่างความปลอดภัยและการใช้งาน	เหมาะกับการทดสอบ
None	อนุญาต cross-site	ต้องใช้ Secure





การรักษาความปลอดภัยของ PHP Session



3. ตั้งค่า Session Cookie ให้ปลอดภัย

Inspect Cookies ด้วย Developer Tools

Developer Tools >> Application >> Cookies >> PHPSESSID

Attribute	Lab07 Expected
HttpOnly	true
SameSite	Lax
Path	/
Secure	ขึ้นอยู่กับ HTTP / HTTPS





การรักษาความปลอดภัยของ PHP Session



4. ตรวจสอบ Session ทุกหน้าที่ต้อง Login เช่นใน auth_check.php ไม่ควรพึ่งแค่การซ่อน URL หรือปุ่มในหน้าเว็บ

```
if (!isset($_SESSION['user_id'])) {  
    header('Location: login.php');  
    exit;  
}
```

5. ตรวจสอบบริบทของ Session เช่น เก็บ User-Agent ตอน Login แล้วเปรียบเทียบกับแต่ละ Request เพื่อช่วยตรวจจับความผิดปกติของ Session

```
$_SESSION['user_agent'] =  
    $_SERVER['HTTP_USER_AGENT'] ?? "";  
  
$currentUserAgent =  
    $_SERVER['HTTP_USER_AGENT'] ?? "";  
  
if (!hash_equals($_SESSION['user_agent'], $currentUserAgent)) {  
    // destroy session  
}
```





การรักษาความปลอดภัยของ PHP Session



6. ทำ Logout อย่างปลอดภัย ควรทำครบ 3 ขั้นตอน

- 1) `$_SESSION = [];`
- 2) ลบ Session Cookie แล้วจึง
- 3) `session_destroy();`

7. ป้องกันข้อมูลสำคัญค้างใน Browser Cache โดยเฉพาะหน้า Profile หรือหน้าหลัง Login

```
header('Cache-Control: no-store, no-cache, must-revalidate');  
header('Pragma: no-cache');
```

no-store: ไม่ให้เก็บสำเนาหน้านี้

no-cache: ก่อนใช้ Cache ต้องตรวจสอบใหม่

must-revalidate: Cache หมดอายุต้องตรวจสอบ Server

Pragma: no-cache: รองรับพฤติกรรมแบบเก่า





การรักษาความปลอดภัยของ PHP Session



8. ไม่เปิดเผย Session ID โดยไม่ควรกระทำ ดังนี้

- แสดงบนหน้าเว็บจริง
- ส่งผ่าน URL
- เขียนลง Log แบบตรง ๆ
- เปิดเผยใน Error Message

9. ใช้ HTTPS เพราะถึงจะตั้งค่า Session ดี แต่ถ้าส่งข้อมูลผ่าน HTTP ผู้โจมตีอาจดัก Session Cookie ได้





เทคนิคการโจมตีรหัสผ่าน



รูปแบบการโจมตีรหัสผ่าน ที่ควรรู้

- Brute Force :เดารหัสผ่านจำนวนมากกับบัญชีเดียว
- Password Spraying: ใช้รหัสผ่านที่พบบ่อยกับหลายบัญชี
- Credential Stuffing: ใช้ Username/Password ที่รั่วจากระบบอื่น
- Username Enumeration: ทหาว่า Username ใด มีอยู่จริงในระบบ ดังนั้นข้อความ Error อาจเปิดเผยว่าบัญชีใดมีอยู่จริง

"Username not found"

ไม่แนะนำ

"Invalid username or password."

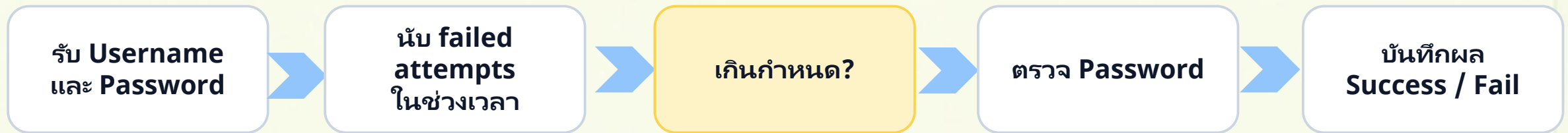
แนะนำ





เทคนิคการโจมตีรหัสผ่าน

แก้ปัญหาการโจมตีรหัสผ่านด้วยการจำกัดการลอง Login ซ้ำภายในช่วงเวลา



องค์ประกอบ	ตัวอย่าง	ความหมาย
Threshold	5 ครั้ง	จำนวนครั้งสูงสุด
Observation Window	5 นาที	ช่วงเวลาที่ใช้ในการนับ
Lockout Duration	ชั่วคราว	เวลาที่ระงับก่อนลองใหม่





เทคนิคการโจมตีรหัสผ่าน



การระงับการเข้าสู่ระบบชั่วคราวและ CAPTCHA แบบปรับตามความเสี่ยง

Login ผิด	การตอบสนอง
1-2 ครั้ง	แสดงข้อความทั่วไป
3-4 ครั้ง	เพิ่ม CAPTCHA
5 ครั้ง	Temporary Lockout
พื้นเวลา	อนุญาตให้ลองใหม่

CAPTCHA ช่วยลด Automation
แต่ไม่ควรใช้แทน Rate Limiting

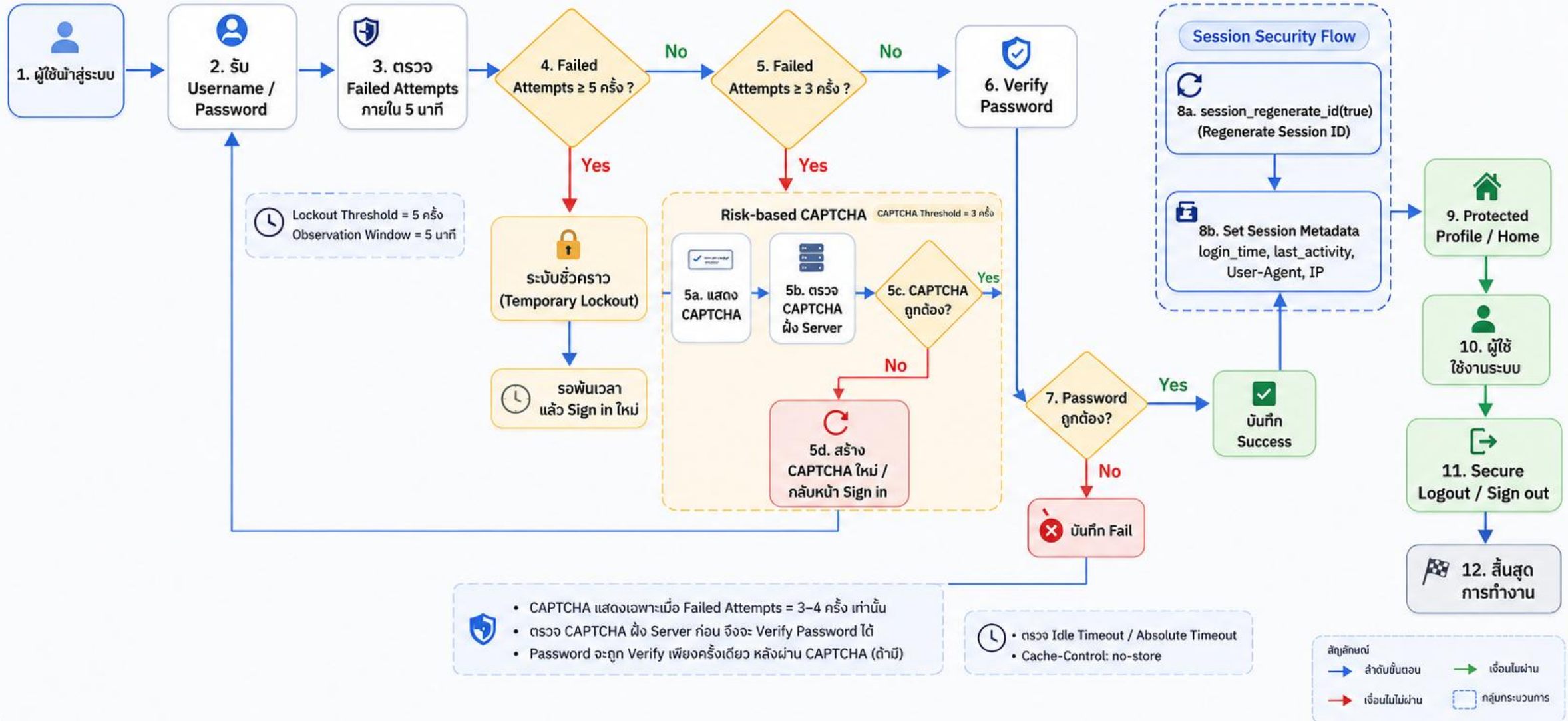
- ตรวจ CAPTCHA ฝั่ง Server
- สร้างโจทย์ใหม่เมื่อผิด
- คำนึงถึง Accessibility





Secure Login Workflow

Session Security + Login Protection



ตัวอย่างการ เข้าสู่ระบบอย่างปลอดภัย



http://localhost:8080/Lec07/login.php

Secure Login Demo

Session Security and Login Protection

Username

Password

Login

Teaching Debug

Session ID before Login: 1662bfc2f69899cecdb7bc1d34292ce3

Failed attempts: 0

CAPTCHA required: No

User Profile

User ID: 1

Username: admin

Role: admin

Login Time: 20:06:32

Last Activity: 20:06:32

Session ID after Login: db944e1e9481b932f130fe273e6a2e7c

Logout

ตาราง login_attempts

id	username	ip_address	attempted_at	success
1	admin	172.18.0.1	2026-08-10 20:06:32	1





ตัวอย่างการ Login/Logout (ต่อ)



ออกจากระบบ (Logout)

User Profile

User ID: 1

Username: admin

Role: admin

Login Time: 20:06:32

Last Activity: 20:06:32

Session ID after Login: db944e1e9481b932f130fe273e6a2e7c

Logout

Secure Login Demo

Session Security and Login Protection

Logout successful.

Username

Password

Login

Teaching Debug

Session ID before Login: d0664f2f5cfe2c36d06726b77337ef98
Failed attempts: 0
CAPTCHA required: No





ตัวอย่างการ Login/Logout (ต่อ)

Secure Login Demo

Session Security and Login Protection

Invalid username or password.

Username

admin

Password

Login

Teaching Debug

Session ID before Login: d0664f2f5cfe2c36d06726b77337ef98

Failed attempts: 1

CAPTCHA required: No

Secure Login Demo

Session Security and Login Protection

Invalid username or password.

Username

admin

Password

CAPTCHA: 2 + 9 = ?

Login

Teaching Debug

Session ID before Login: d0664f2f5cfe2c36d06726b77337ef98

Failed attempts: 3

CAPTCHA required: Yes

Secure Login Demo

Session Security and Login Protection

Too many failed login attempts. Please try again later.

Username

admin

Password

Login

Teaching Debug

Session ID before Login: d0664f2f5cfe2c36d06726b77337ef98

Failed attempts: 5

CAPTCHA required: No



ตัวอย่างการ Login/Logout (ต่อ)

โครงสร้างฐานข้อมูล: ใช้ฐานข้อมูลเดิม db_login_demo และทำงานร่วมกับตาราง users

สร้างฐานตาราง
login_attempts

```
CREATE TABLE IF NOT EXISTS login_attempts (  
  id INT AUTO_INCREMENT PRIMARY KEY,  
  username VARCHAR(50) NOT NULL,  
  ip_address VARCHAR(45) NOT NULL,  
  attempted_at DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,  
  success TINYINT(1) NOT NULL DEFAULT 0,  
  INDEX idx_login_attempts_username_time (username, attempted_at)  
);
```


ตัวอย่างการ Login/Logout (ต่อ)

โครงสร้างฐานข้อมูล: ใช้ฐานข้อมูลเดิม db_login_demo และทำงานร่วมกับตาราง users

ตาราง users

id	username	password_hash	role
1	admin	\$2y\$10\$SZgFDih5sq72SL5/8.bvg.sDz3mGOBriRyYgPQzggXy...	admin
2	student	\$2y\$10\$Tthj8FmXiJwxugXZt7Dzh.t5Wlcp/Zoa1v5zlgWVXXU...	user

ตาราง db_login_demo

Name	Type	Collation	Attributes	Null	Default	Comments	Extra
id 	int(11)			No	None		AUTO_INCREMENT
username 	varchar(50)	utf8mb4_unicode_ci		No	None		
ip_address	varchar(45)	utf8mb4_unicode_ci		No	None		
attempted_at 	datetime			No	current_timestamp()		
success	tinyint(1)			No	0		



ตัวอย่างการ Login/Logout (ต่อ)

โครงสร้างไฟล์ของระบบ Login/Logout

- config.php: ตั้งค่าฐานข้อมูล, Session/Cookie, Timeout และฟังก์ชันที่ใช้ร่วมกัน
- login.php: แสดงฟอร์ม Login รับ Username/Password และแสดง CAPTCHA/ข้อความสถานะ
- login_process.php: ตรวจสอบ Login Attempts, CAPTCHA และ Password จากนั้นสร้าง Session เมื่อ Login สำเร็จ
- auth_check.php: ตรวจสอบสถานะ Login, Idle/Absolute Timeout, User-Agent และป้องกัน Cache
- profile.php: หน้า Protected Page แสดงข้อมูลผู้ใช้ที่ Login สำเร็จจาก Session
- logout.php: ล้าง Session, ลบ Session Cookie และทำลาย Session อย่างปลอดภัย

Lec07/

- config.php
- login.php
- login_process.php
- auth_check.php
- profile.php
- logout.php



ตัวอย่างการ Login/Logout (ต่อ)

ไฟล์ config.php

```
<?php
declare(strict_types=1);
date_default_timezone_set('Asia/Bangkok');

const DB_HOST = 'db';
const DB_PORT = 3306;
const DB_NAME = 'db_login_demo';
const DB_USER = 'root';
const DB_PASS = 'root';

// ค่าสำหรับ Demo const IDLE_TIMEOUT = 60; // 60 วินาที
const ABSOLUTE_TIMEOUT = 120; // 2 นาที
const LOGIN_WINDOW_SECONDS = 300; // นับ Login ผิดย้อนหลัง 5 นาที
const CAPTCHA_AFTER_ATTEMPTS = 3; // เริ่ม CAPTCHA เมื่อผิดครบ 3 ครั้ง
const MAX_LOGIN_ATTEMPTS = 5; // ผิดครบ 5 ครั้ง = Temporary Lockout

mysqli_report(MYSQLI_REPORT_ERROR | MYSQLI_REPORT_STRICT);
```

ตัวอย่างการ Login/Logout (ต่อ)

ไฟล์ config.php (ต่อ)

```
/* Session Cookie Security
 * ถ้าใช้ http://localhost ค่า Secure จะเป็น false
 */
$isHttps = isset($_SERVER['HTTPS']) && $_SERVER['HTTPS'] !== 'off';
session_set_cookie_params([
    'lifetime' => 0,
    'path' => '/',
    'domain' => '',
    'secure' => $isHttps,
    'httponly' => true,
    'samesite' => 'Lax'
]);

session_start();
```



ตัวอย่างการ Login/Logout (ต่อ)



ไฟล์ config.php (ต่อ)

```
try {
    $conn = new mysqli(DB_HOST, DB_USER, DB_PASS, DB_NAME, DB_PORT);
    $conn->set_charset('utf8mb4');
    $conn->query("SET time_zone = '+07:00'");
} catch (mysqli_sql_exception $e) {
    http_response_code(500);
    error_log($e->getMessage());
    exit('Database connection failed.');
```



```
function h(?string $value): string
{
    return htmlspecialchars(
        $value ?? "",
        ENT_QUOTES | ENT_SUBSTITUTE,
        'UTF-8'
    );
}
```





ตัวอย่างการ Login/Logout (ต่อ)



ไฟล์ config.php (ต่อ)

```
/* นับจำนวน Login ที่ไม่สำเร็จของ Username ภายในช่วงเวลาที่กำหนด */  
function get_failed_attempts(mysqli $conn, string $username): int  
{  
    if ($username === "") {  
        return 0;  
    }  
    $cutoff = date(  
        'Y-m-d H:i:s',  
        time() - LOGIN_WINDOW_SECONDS  
    );  
  
    $sql = "  
        SELECT COUNT(*) AS failed_count  
        FROM login_attempts  
        WHERE username = ?  
        AND success = 0  
        AND attempted_at >= ?  
    ";
```

```
    $stmt = $conn->prepare($sql);  
    $stmt->bind_param('ss', $username, $cutoff);  
    $stmt->execute();  
  
    $row = $stmt->get_result()->fetch_assoc();  
    $stmt->close();  
  
    return (int) ($row['failed_count'] ?? 0);  
}
```



ตัวอย่างการ Login/Logout (ต่อ)

ไฟล์ config.php (ต่อ)

```
//CAPTCHA แบบคณิตศาสตร์อย่างง่ายใช้เพื่อสาธิต
function create_captcha(): void
{
    $number1 = random_int(1, 9);
    $number2 = random_int(1, 9);
    $_SESSION['captcha_question'] =
        $number1 . ' + ' . $number2 . ' = ?';
    $_SESSION['captcha_answer'] =
        $number1 + $number2;
}

function clear_captcha(): void
{
    unset(
        $_SESSION['captcha_question'],
        $_SESSION['captcha_answer']
    );
}
```

//ทำลาย Session อย่างปลอดภัย

```
function destroy_session_safely(): void
{
    $_SESSION = [];
    if (ini_get('session.use_cookies')) {
        $params = session_get_cookie_params();
        setcookie(
            session_name(),
            '',
            [ 'expires' => time() - 42000,
              'path' => $params['path'],
              'domain' => $params['domain'],
              'secure' => $params['secure'],
              'httponly' => $params['httponly'],
              'samesite' => $params['samesite'] ?? 'Lax'
            ],
        );
    }
    session_destroy();
}
```



ตัวอย่างการ Login/Logout (ต่อ)



ไฟล์ login.php

```
<?php
declare(strict_types=1);
require_once 'config.php';

if (isset($_SESSION['user_id'])) {
    header('Location: profile.php');
    exit;
}

$error = $_GET['error'] ?? '';
$message = $_GET['message'] ?? '';
```

```
// จำ Username ล่าสุดเพื่อใช้ตัดสินใจว่าเมื่อใดต้องแสดง CAPTCHA
$username = $_SESSION['login_form_username'] ?? '';
$failedCount = get_failed_attempts($conn, $username);
```

```
$showCaptcha =
    $failedCount >= CAPTCHA_AFTER_ATTEMPTS &&
    $failedCount < MAX_LOGIN_ATTEMPTS;

if ($showCaptcha && !isset($_SESSION['captcha_answer'])) {
    create_captcha();
}
?>
```





ตัวอย่างการ Login/Logout (ต่อ)



ไฟล์ login.php (ต่อ)

```
<!doctype html>
<html lang="en">
<head>
  <meta charset="utf-8">
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <title>Secure Login Demo</title>
  <style>
    body {
      font-family: Arial, sans-serif; background: #f3f6f9;
      margin: 0;
    }
    .card {
      width: min(480px, 92%); margin: 50px auto;
      padding: 30px; background: #fff;
      border-radius: 12px;
      box-shadow: 0 8px 30px rgba(0,0,0,.08);
    }
```

```
.group { margin-bottom: 18px;
}
label {
  display: block; margin-bottom: 7px;
  font-weight: bold;
}
input {
  width: 100%; padding: 11px;
  box-sizing: border-box;
}
button {
  width: 100%; padding: 11px;
  border: 0; border-radius: 8px;
  background: #0d6efd; color: #fff;
  font-weight: bold;
  cursor: pointer;
}
```



ตัวอย่างการ Login/Logout (ต่อ)

ไฟล์ login.php (ต่อ)

```
.error {  
    margin-bottom: 18px; padding: 12px;  
    background: #f8d7da; color: #842029;  
}  
.success {  
    margin-bottom: 18px; padding: 12px;  
    background: #d1e7dd; color: #0f5132;  
}  
.captcha {  
    padding: 14px; margin-bottom: 18px;  
    background: #eef6ff; border: 1px solid #b6d4fe;  
    border-radius: 8px;  
}
```

```
.debug {  
    margin-top: 18px;  
    padding: 10px;  
    background: #fff3cd; word-break: break-all;  
    font-size: 14px;  
}  
.hint {  
    font-size: 14px;  
    color: #555;  
}  
</style>  
</head>
```

ตัวอย่างการ Login/Logout (ต่อ)

ไฟล์ login.php (ต่อ)

```
<body>
<div class="card">
  <h1>Secure Login Demo</h1>
  <p class="hint">Session Security and Login Protection</p>
  <?php if ($error === 'invalid'): ?>
    <div class="error">Invalid username or password.</div>

  <?php elseif ($error === 'empty'): ?>
    <div class="error">Username and password are required.</div>

  <?php elseif ($error === 'captcha'): ?>
    <div class="error">Invalid CAPTCHA. Please try again.</div>

  <?php elseif ($error === 'locked'): ?>
    <div class="error">
      Too many failed login attempts. Please try again later.
    </div>
```

Secure Login Demo

Session Security and Login Protection

Invalid username or password.

Username

admin

Password

Login

Teaching Debug

Session ID before Login: d0664f2f5cfe2c36d06726b77337ef98

Failed attempts: 1

CAPTCHA required: No



ตัวอย่างการ Login/Logout (ต่อ)



ไฟล์ login.php (ต่อ)

```
<?php elseif ($error === 'idle_timeout'): ?>
    <div class="error">
        Session expired because of inactivity. Please login again.
    </div>
<?php elseif ($error === 'absolute_timeout'): ?>
    <div class="error">
        Maximum session time expired. Please login again.
    </div>
<?php elseif ($error === 'session_changed'): ?>
    <div class="error">
        Browser information changed. Please login again.
    </div>
<?php endif; ?>
<?php if ($message === 'logout'): ?>
    <div class="success">Logout successful.</div>
<?php endif; ?>
```

Secure Login Demo

Session Security and Login Protection

Session expired because of inactivity. Please login again.

Username

Password

Login

Teaching Debug

Session ID before Login: fa9e661d6e1af59c1b64e2e161b2f669

Failed attempts: 0

CAPTCHA required: No



ตัวอย่างการ Login/Logout (ต่อ)

ไฟล์ login.php (ต่อ)

```
<form action="login_process.php" method="post">
  <div class="group">
    <label for="username">Username</label>
    <input type="text" id="username" name="username"
      maxlength="50" value="<?= h($username) ?>"
      autocomplete="username" required >
  </div>

  <div class="group">
    <label for="password">Password</label>
    <input type="password" id="password"
      name="password" autocomplete="current-password"
      required >
  </div>
```

Secure Login Demo

Session Security and Login Protection

Username

Password

Login

Teaching Debug

Session ID before Login: 1662bfc2f69899cecd7bc1d34292ce3
Failed attempts: 0
CAPTCHA required: No

ตัวอย่างการ Login/Logout (ต่อ)

ไฟล์ login.php (ต่อ)

```
<?php if ($showCaptcha): ?>
    <div class="captcha">
        <label for="captcha">
            CAPTCHA: <?= h($_SESSION['captcha_question'] ?? '') ?>
        </label>
        <input type="number" id="captcha" name="captcha" required >
    </div>
<?php endif; ?>
<button type="submit">Login</button>
</form>
```

<!-- ใช้เพื่อการสาธิตในชั้นเรียนเท่านั้น -->

```
<div class="debug">
    <strong>Teaching Debug</strong><br>
    Session ID before Login: <?= h(session_id()) ?><br>
    Failed attempts: <?= $failedCount ?><br>
    CAPTCHA required: <?= $showCaptcha ? 'Yes' : 'No' ?>
</div> </div> </body> </html>
```

Secure Login Demo

Session Security and Login Protection

Invalid username or password.

Username

admin

Password

CAPTCHA: 5 + 5 = ?

Login

Teaching Debug

Session ID before Login: b3aa19ada35c7343327f028e260364fa
Failed attempts: 3
CAPTCHA required: Yes

ตัวอย่างการ Login/Logout (ต่อ)

ไฟล์ login_process.php

```
<?php
declare(strict_types=1);
require_once 'config.php';
if ($_SERVER['REQUEST_METHOD'] !== 'POST') {
    header('Location: login.php');
    exit;
}
$username = trim($_POST['username'] ?? '');
$password = $_POST['password'] ?? '';
$ipAddress = $_SERVER['REMOTE_ADDR'] ?? 'unknown';

// จำ Username ล่าสุดเพื่อให้หน้า Login รู้ว่าต้องแสดง CAPTCHA หรือไม่
$_SESSION['login_form_username'] = $username;
if ($username === '' || $password === '') {
    header('Location: login.php?error=empty');
    exit;
}
```



ตัวอย่างการ Login/Logout (ต่อ)



ไฟล์ login_process.php (ต่อ)

```
// STEP 1: ตรวจสอบ Login ผิด
$failedCount = get_failed_attempts($conn, $username);

// STEP 2: Temporary Lockout
if ($failedCount >= MAX_LOGIN_ATTEMPTS) {
    clear_captcha();
    header('Location: login.php?error=locked');
    exit;
}

// STEP 3: Adaptive CAPTCHA เมื่อ Login ผิดครบ 3 ครั้ง ต้องตอบ CAPTCHA ก่อน
if ($failedCount >= CAPTCHA_AFTER_ATTEMPTS) {
    $captchaInput = filter_input(
        INPUT_POST,
        'captcha',
        FILTER_VALIDATE_INT
    );
```

```
$expectedAnswer =
    $_SESSION['captcha_answer'] ?? null;
if (
    $captchaInput === false ||
    $captchaInput === null ||
    $expectedAnswer === null ||
    $captchaInput !== (int) $expectedAnswer
) {
    clear_captcha();
    header('Location: login.php?error=captcha');
    exit;
}

// ผ่านแล้ว ไม่ให้ใช้คำตอบเดิมซ้ำ
clear_captcha();
}
```



ตัวอย่างการ Login/Logout (ต่อ)



ไฟล์ login_process.php (ต่อ)

/* STEP 4: ค้นหาผู้ใช้

ตาราง users ของ db_login_demo มี:

id, username, password_hash, role

*/

```
$sql = " SELECT id, username, password_hash, role  
FROM users  
WHERE username = ? ";
```

```
$stmt = $conn->prepare($sql);  
$stmt->bind_param('s', $username);  
$stmt->execute();
```

```
$user = $stmt->get_result()->fetch_assoc();  
$stmt->close();
```

// STEP 5: ตรวจสอบ Password

```
$loginSuccess = $user !== null &&  
    password_verify( $password, $user['password_hash'] );
```

```
$successValue = $loginSuccess ? 1 : 0;
```

/* STEP 6: บันทึก Login Attempt ไม่เก็บ Password ที่ผู้ใช้กรอก

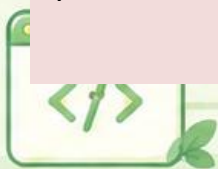
```
$logSql = " INSERT INTO login_attempts  
    (username, ip_address, success)  
VALUES (?, ?, ?) ";
```

```
$logStmt = $conn->prepare($logSql);
```

```
$logStmt->bind_param(  
    'ssi',  
    $username,  
    $ipAddress,  
    $successValue );
```

```
$logStmt->execute();
```

```
$logStmt->close();
```





ตัวอย่างการ Login/Logout (ต่อ)



ไฟล์ login_process.php (ต่อ)

```
// Login ไม่สำเร็จ
if (!$loginSuccess) {
    clear_captcha();
    header('Location: login.php?error=invalid');
    exit;
}
/* STEP 7: Login สำเร็จ
สร้าง Session ID ใหม่เพื่อช่วยป้องกัน Session Fixation */
session_regenerate_id(true);
$_SESSION['user_id'] = (int) $user['id'];
$_SESSION['username'] = $user['username'];
$_SESSION['role'] = $user['role'];
$_SESSION['login_time'] = time();
$_SESSION['last_activity'] = time();
$_SESSION['user_agent'] = $_SERVER['HTTP_USER_AGENT'] ?? '';
$_SESSION['login_ip'] = $ipAddress;
```

```
// ล้างข้อมูลที่ใช้เฉพาะหน้า Login
unset($_SESSION['login_form_username']);
clear_captcha();

// Login สำเร็จแล้ว ล้างประวัติ Login ผิดของ Username นี้
$sql = "DELETE FROM login_attempts
        WHERE username = ?
        AND success = 0";

$stmt = $conn->prepare($sql);
$stmt->bind_param('s', $username);
$stmt->execute();
$stmt->close();

header('Location: profile.php');
exit;
```



ตัวอย่างการ Login/Logout (ต่อ)

ไฟล์ auth_check.php

```
<?php
declare(strict_types=1);
require_once 'config.php';

// ลดการแสดงผลข้อมูล Profile เดิมจาก Browser Cache หลัง Logout
header('Cache-Control: no-store, no-cache, must-revalidate');
header('Pragma: no-cache');

// ต้องผ่าน Login ก่อน
if (!isset($_SESSION['user_id'])) {
    header('Location: login.php');
    exit;
}

$currentTime = time();
```

ตัวอย่างการ Login/Logout (ต่อ)

ไฟล์ auth_check.php

```
// Idle Timeout
if (
    isset($_SESSION['last_activity']) &&
    ($currentTime - (int) $_SESSION['last_activity']) > IDLE_TIMEOUT
) {
    destroy_session_safely();
    header('Location: login.php?error=idle_timeout');
    exit;
}

// Absolute Timeout
if (
    isset($_SESSION['login_time']) &&
    ($currentTime - (int) $_SESSION['login_time']) > ABSOLUTE_TIMEOUT
) {
    destroy_session_safely();
    header('Location: login.php?error=absolute_timeout');
    exit;
}
```



ตัวอย่างการ Login/Logout (ต่อ)



ไฟล์ auth_check.php

```
//Session Context Checking: User-Agent
$currentUserAgent =
    $_SERVER['HTTP_USER_AGENT'] ?? '';

$storedUserAgent =
    $_SESSION['user_agent'] ?? '';

if (!hash_equals($storedUserAgent, $currentUserAgent)) {
    destroy_session_safely();

    header('Location: login.php?error=session_changed');
    exit;
}
```



```
// IP เปลี่ยน -> บันทึก Log เท่านั้น
$currentIp =
    $_SERVER['REMOTE_ADDR'] ?? 'unknown';

if (
    isset($_SESSION['login_ip']) &&
    $_SESSION['login_ip'] !== $currentIp
) {
    error_log(
        'Session IP changed for user ID: ' .
        (string) $_SESSION['user_id']
    );
}

//Request กิจกรรมล่าสุด
$_SESSION['last_activity'] = $currentTime;
```

ตัวอย่างการ Login/Logout (ต่อ)

ไฟล์ profile.php

```
<?php
declare(strict_types=1);
require_once 'auth_check.php'; ?>
<!doctype html>
<html lang="en">
<head>
  <meta charset="utf-8">
  <meta name="viewport" content="width=device-width, initial-scale=1">
  <title>User Profile</title>

  <style>
    body { font-family: Arial, sans-serif; background: #f3f6f9;
    }
    .card {width: min(650px, 92%); margin: 60px auto;
      padding: 30px; background: #fff; border-radius: 12px;
    }
  </style>
```

User Profile

User ID:	1
Username:	admin
Role:	admin
Login Time:	20:06:32
Last Activity:	20:06:32

Session ID after Login: db944e1e9481b932f130fe273e6a2e7c

Logout

ตัวอย่างการ Login/Logout (ต่อ)

ไฟล์ profile.php

```
.row {  
    padding: 12px 0; border-bottom: 1px solid #e5e7eb;  
}  
.label {  
    display: inline-block; min-width: 150px; font-weight: bold;  
}  
.logout {  
    display: inline-block; margin-top: 24px; padding: 10px 18px;  
    background: #dc3545; color: #fff; text-decoration: none;  
    border-radius: 8px; font-weight: bold;  
}  
.debug { margin-top: 20px; padding: 12px;  
    background: #fff3cd; word-break: break-all;  
}  
</style>  
</head>
```

User Profile

User ID:	1
Username:	admin
Role:	admin
Login Time:	20:06:32
Last Activity:	20:06:32

Session ID after Login: db944e1e9481b932f130fe273e6a2e7c

Logout

ตัวอย่างการ Login/Logout (ต่อ)

ไฟล์ profile.php

```
<body>
<div class="card">
  <h1>User Profile</h1>

  <div class="row">
    <span class="label">User ID:</span>
    <?= (int) ($_SESSION['user_id'] ?? 0) ?>
  </div>

  <div class="row">
    <span class="label">Username:</span>
    <?= h($_SESSION['username'] ?? "") ?>
  </div>

  <div class="row">
    <span class="label">Role:</span>
    <?= h($_SESSION['role'] ?? "") ?>
  </div>
```

User Profile

User ID: 1

Username: admin

Role: admin

Login Time: 20:06:32

Last Activity: 20:06:32

Session ID after Login: db944e1e9481b932f130fe273e6a2e7c

Logout

ตัวอย่างการ Login/Logout (ต่อ)

ไฟล์ profile.php

```
<div class="row">
    <span class="label">Login Time:</span>
    <?= date('H:i:s', (int) $_SESSION['login_time']) ?>
</div>

<div class="row">
    <span class="label">Last Activity:</span>
    <?= date('H:i:s', (int) $_SESSION['last_activity']) ?>
</div>
<!-- ใช้เพื่อสาธิตในชั้นเรียนเท่านั้น -->
<div class="debug">
    Session ID after Login: <?= h(session_id()) ?>
</div>

<a class="logout" href="logout.php">
    Logout
</a>
</div></body></html>
```

User Profile

User ID:	1
Username:	admin
Role:	admin
Login Time:	20:06:32
Last Activity:	20:06:32

Session ID after Login: db944e1e9481b932f130fe273e6a2e7c

Logout



ตัวอย่างการ Login/Logout (ต่อ)



ไฟล์ logout.php

```
<?php  
declare(strict_types=1);  
  
require_once 'config.php';  
  
destroy_session_safely();  
  
header('Location: login.php?message=logout');  
exit;
```



กรณีทดสอบการ Login/Logout

1. Login ด้วยข้อมูลถูกต้อง สามารถเข้าหน้า Profile แสดงข้อมูลที่ถูกต้อง

Secure Login Demo

Session Security and Login Protection

Username

Password

Login

Teaching Debug

Session ID before Login: 7f73ec1b23076e688ac7206133db3dfb

Failed attempts: 0

CAPTCHA required: No

User Profile

User ID: 1

Username: admin

Role: admin

Login Time: 21:30:18

Last Activity: 21:30:18

Session ID after Login: cf012be39a7945419930b55b867f8838

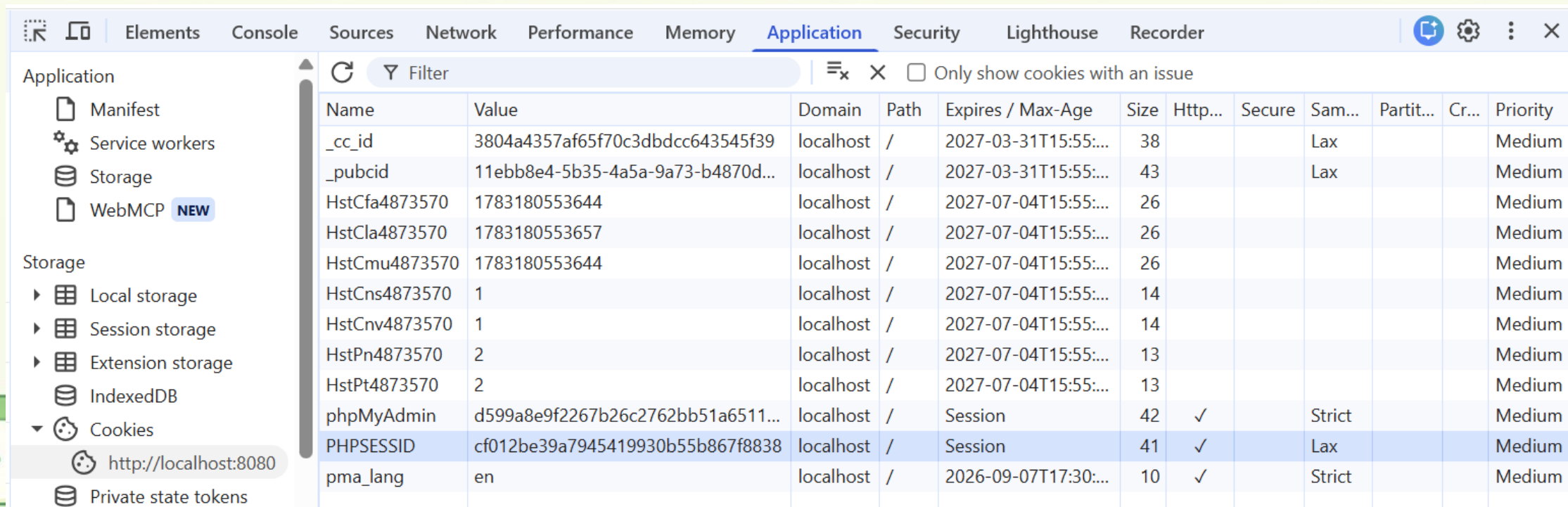
Logout

id	username	ip_address	attempted_at	success
1	admin	172.18.0.1	2026-08-10 21:30:18	1

กรณีทดสอบการ Login/Logout

2. การตรวจสอบ Cookie Security Flags โดย Login เข้าสู่ระบบให้สำเร็จ

- เปิด Developer Tools ของ Browser
- เลือก Application >> Cookies >> http://localhost:8080
- ตรวจสอบ Cookie ชื่อ PHPSESSID



The screenshot shows the Chrome DevTools Application tab with the 'Cookies' section selected for the URL 'http://localhost:8080'. The table lists several cookies, with 'PHPSESSID' highlighted. The 'PHPSESSID' cookie has a 'Secure' flag checked and a 'Priority' of 'Medium'.

Name	Value	Domain	Path	Expires / Max-Age	Size	Http...	Secure	Sam...	Partit...	Cr...	Priority
_cc_id	3804a4357af65f70c3dbdcc643545f39	localhost	/	2027-03-31T15:55:...	38			Lax			Medium
_pubcid	11ebb8e4-5b35-4a5a-9a73-b4870d...	localhost	/	2027-03-31T15:55:...	43			Lax			Medium
HstCfa4873570	1783180553644	localhost	/	2027-07-04T15:55:...	26						Medium
HstCla4873570	1783180553657	localhost	/	2027-07-04T15:55:...	26						Medium
HstCmu4873570	1783180553644	localhost	/	2027-07-04T15:55:...	26						Medium
HstCns4873570	1	localhost	/	2027-07-04T15:55:...	14						Medium
HstCnv4873570	1	localhost	/	2027-07-04T15:55:...	14						Medium
HstPn4873570	2	localhost	/	2027-07-04T15:55:...	13						Medium
HstPt4873570	2	localhost	/	2027-07-04T15:55:...	13						Medium
phpMyAdmin	d599a8e9f2267b26c2762bb51a6511...	localhost	/	Session	42	✓		Strict			Medium
PHPSESSID	cf012be39a7945419930b55b867f8838	localhost	/	Session	41	✓	✓	Lax			Medium
pma_lang	en	localhost	/	2026-09-07T17:30:...	10	✓		Strict			Medium

กรณีทดสอบการ Login/Logout

3. การทดสอบ Idle Timeout

- Login เข้าสู่ระบบให้สำเร็จและอยู่ที่โดยไม่ Refresh และไม่ใช้งานระบบเป็นเวลาเกิน 60 วินาที

Secure Login Demo

Session Security and Login Protection

Session expired because of inactivity. Please login again.

Username

Password

Login

Teaching Debug

Session ID before Login: fa9e661d6e1af59c1b64e2e161b2f669

Failed attempts: 0

CAPTCHA required: No

กรณีทดสอบการ Login/Logout

4. การทดสอบ Absolute Timeout

- Login เข้าสู่ระบบให้สำเร็จ profile.php ทุกประมาณ 20–30 วินาที เพื่อไม่ให้เกิด Idle Timeout ใช้งานต่อเนื่องจนเวลาหลัง Login เกิน 120 วินาที

Secure Login Demo

Session Security and Login Protection

Maximum session time expired. Please login again.

Username

Password

Login

Teaching Debug

Session ID before Login: cbd16a6c11b6b950ca99d2ceac07e9a7
Failed attempts: 0
CAPTCHA required: No

กรณีทดสอบการ Login/Logout

5. การทดสอบ Login Attempt Limiting

- Login ด้วย password ที่ไม่ถูกต้อง เช่น **Username:** admin, **Password:** Admin1
- ให้ Login ผิดให้ครบ 5 ครั้งภายใน 5 นาที

Secure Login Demo

Session Security and Login Protection

Too many failed login attempts. Please try again later.

Username

admin

Password

Login

Teaching Debug

Session ID before Login: cbd16a6c11b6b950ca99d2ceac07e9a7

Failed attempts: 5

CAPTCHA required: No

ตาราง login_attempts

id	username	ip_address	attempted_at	success
1	admin	172.18.0.1	2026-08-10 21:30:18	1
27	admin	172.18.0.1	2026-08-10 21:39:54	1
28	admin	172.18.0.1	2026-08-10 21:40:39	1
29	admin	172.18.0.1	2026-08-10 21:49:36	0
30	admin	172.18.0.1	2026-08-10 21:49:45	0
31	admin	172.18.0.1	2026-08-10 21:49:50	0
32	admin	172.18.0.1	2026-08-10 21:50:06	0
33	admin	172.18.0.1	2026-08-10 21:50:15	0

กรณีทดสอบการ Login/Logout

6. การทดสอบการ Login หลังพ้นช่วงเวลาระงับ

- รอให้พ้นช่วงเวลาที่กำหนด
- `const LOGIN_WINDOW_SECONDS = 300; // 5 นาที`

User Profile

User ID: 1

Username: admin

Role: admin

Login Time: 21:59:10

Last Activity: 21:59:11

Session ID after Login: 46459a2784d11c28a4df16e08d1cd49f

Logout

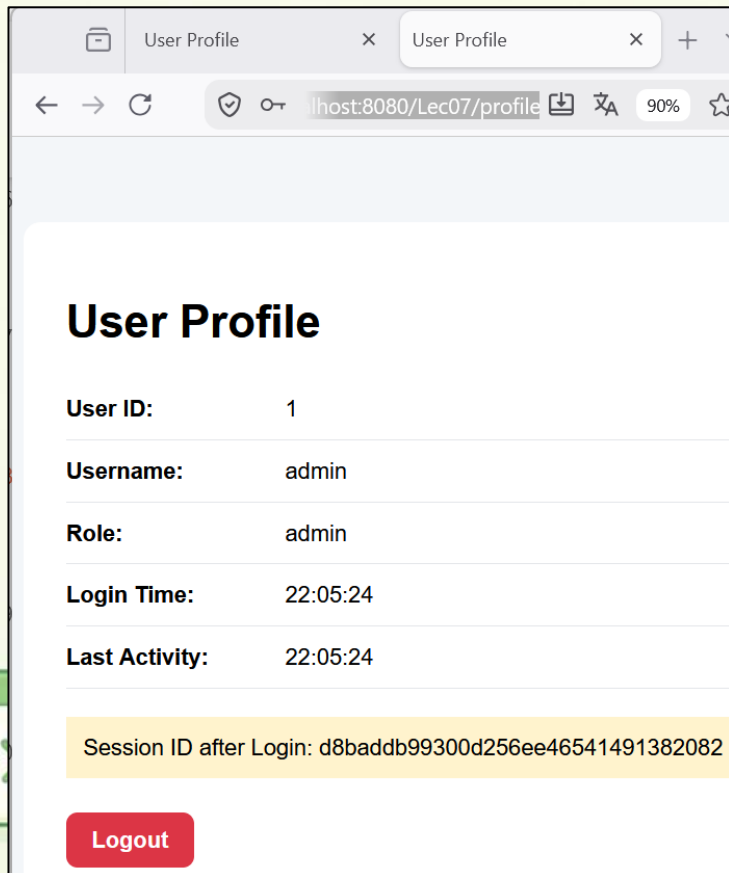
ตาราง login_attempts

id	username	ip_address	attempted_at	success
1	admin	172.18.0.1	2026-08-10 21:30:18	1
27	admin	172.18.0.1	2026-08-10 21:39:54	1
28	admin	172.18.0.1	2026-08-10 21:40:39	1
35	admin	172.18.0.1	2026-08-10 21:59:10	1

กรณีทดสอบการ Login/Logout

7. การทดสอบ Secure Logout ด้วยหลาย Tab

- Login เข้าสู่ระบบให้สำเร็จ เปิดหน้า <http://localhost:8080/Lec07/profile.php> จำนวน 2 Tab
- ที่ Tab แรก ให้กดปุ่ม Logout

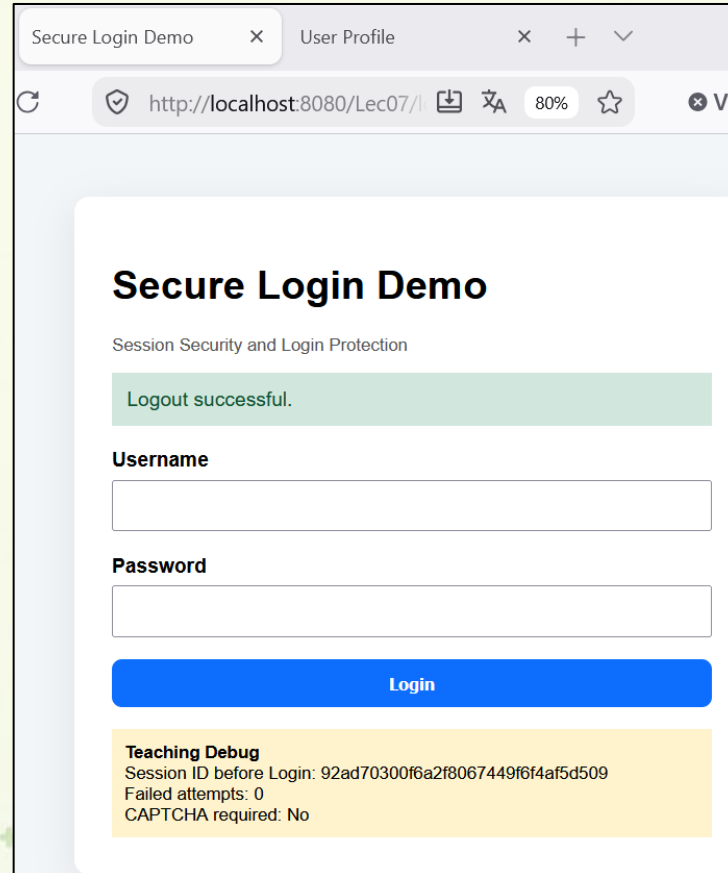


User Profile

User ID:	1
Username:	admin
Role:	admin
Login Time:	22:05:24
Last Activity:	22:05:24

Session ID after Login: d8baddb99300d256ee46541491382082

Logout



Secure Login Demo

Session Security and Login Protection

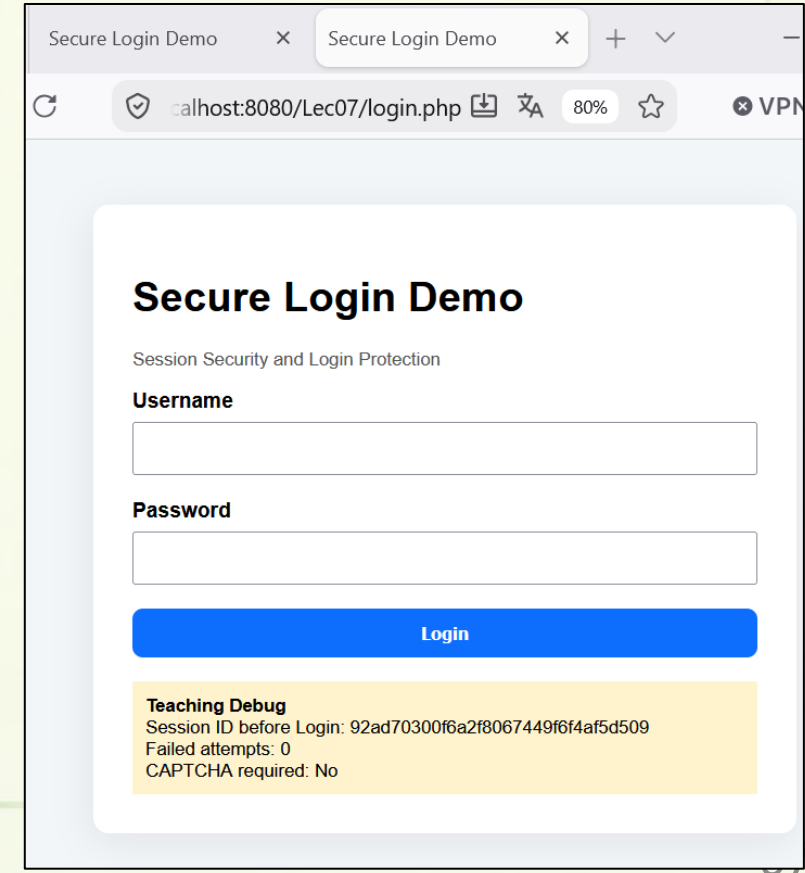
Logout successful.

Username

Password

Login

Teaching Debug
Session ID before Login: 92ad70300f6a2f8067449f6f4af5d509
Failed attempts: 0
CAPTCHA required: No



Secure Login Demo

Session Security and Login Protection

Username

Password

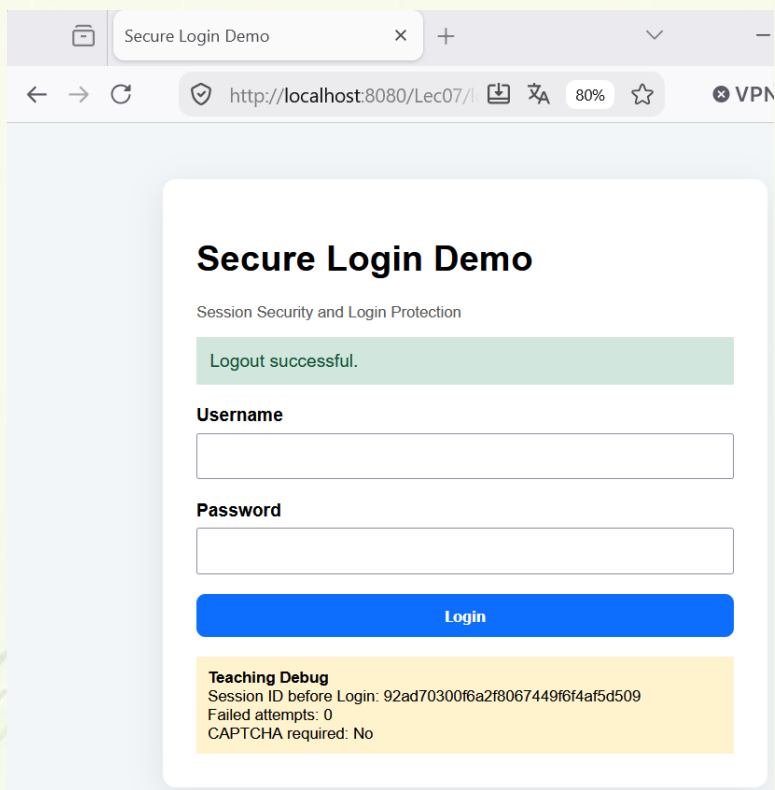
Login

Teaching Debug
Session ID before Login: 92ad70300f6a2f8067449f6f4af5d509
Failed attempts: 0
CAPTCHA required: No

กรณีทดสอบการ Login/Logout

8. การทดสอบ Cache Control หลัง Logout

- Login เข้าสู่ระบบและเปิดหน้า profile.php กดปุ่ม Logout
- หลังจากกลับไปหน้า Login ให้กดปุ่ม Back ของ Browser



Secure Login Demo

Session Security and Login Protection

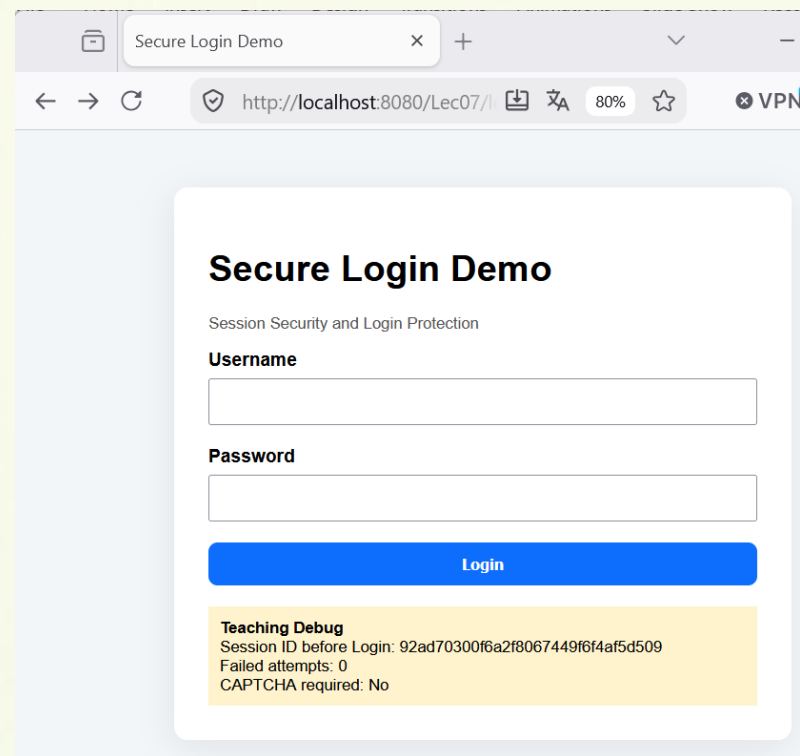
Logout successful.

Username

Password

Login

Teaching Debug
Session ID before Login: 92ad70300f6a2f8067449f6f4af5d509
Failed attempts: 0
CAPTCHA required: No



Secure Login Demo

Session Security and Login Protection

Username

Password

Login

Teaching Debug
Session ID before Login: 92ad70300f6a2f8067449f6f4af5d509
Failed attempts: 0
CAPTCHA required: No



อ้างอิง



- PHP Documentation. Session Handling Functions.
- PHP Documentation. Password Hashing Functions.
- PHP Documentation. MySQLi Prepared Statements.
- OWASP Foundation. Session Management Cheat Sheet.
- OWASP Foundation. Password Storage Cheat Sheet.
- OWASP Foundation. SQL Injection Prevention Cheat Sheet.
- Oracle. MySQL Reference Manual: Prepared Statements.

